



TRUST404 · TRACK 04

AutoPoC

Autonomous Exploit-Proof Agent

취약점 "**의심**"을 보고서로 남기지 않는다.
공격이 실제로 성립함을 **실행되는 PoC로 스스로 증명**하는 에이전트.

실행 증명 기반

오프라인 결정론

오탐 0

미공개 유형 일반화

01 문제 정의

- ◆ 감사의 병목은 "확인"이다. 정적 분석·LLM 도구는 취약 가능성을 쏟아내지만, 진짜 성립 여부 판단은 사람 몫 — 느리고 비싸다.
- ◆ "가능성 리포트"는 신뢰할 수 없다. 오탐(false positive)이 섞여 있어, 리포트 한 줄마다 사람이 다시 검증해야 한다.
- ◆ 재현이 어렵다. 같은 입력에도 결과가 흔들리면 회귀 검증·감사 추적이 불가능하다.
- ◆ → 필요한 것: 공격 성립을 스스로 · 재현 가능하게 · 오탐 없이 증명하는 자율 에이전트.

02 위협 모델

입력 & 공격자 능력

타깃 컨트랙트 소스 + 불변식(*Invariants*) + manifest를 입력받는다. 공격자는 임의 트랜잭션 시퀀스·재진입·외부 콜·자금 이동을 수행할 수 있다.

신뢰 경계

LLM은 **소스 추론만** 한다 — 파일·웹 접근 없음, 타깃별 정답 하드코딩 없음. 모든 후보는 하네스 실행으로만 채택된다.

성공의 정의

조직위 하네스 `!Invariants.checkAll`이 실제로 깨져야만 성공. **에이전트도 LLM도 판정 권한이 없다** — 판정은 forge 실행뿐.

안전장치

멀쩡한 타깃엔 거짓 성공을 만들지 않고 **기권(exit 1)**. 네트워크는 허용된 LLM API 예외만 — 오프라인에선 완전 차단으로도 동작.

03 동작 방식



각 후보 → 하네스 실행 → **checkAll이 깨지면 PROVEN**, 아니면 다음 후보. 정답 하드코딩 없이 소스·퍼징·추론에서만 유도.

- ◆ 오프라인 우선 — 싼 결정론 두뇌를 클라우드보다 앞세워 결정론 강화 + API 비용 절감.
- ◆ 판정 권한은 하네스뿐 — 에이전트·LLM은 성공을 선언하지 못한다.

04 검증 결과

6/6

공개셋
(취약 4 발견 + 멀쩡 2 기권)

8/8

포팅 미공개 유형
(클라우드 폴백)

14/14

종료코드 정확
(발견 0 / 기권 1)

100%

결정론
바이트 동일 재현

항목	결과	근거
공개셋 4종 취약점	전부 오프라인 발견	재진입·퍼저·휴리스틱, 네트워크 차단 하에서도 PROVEN
멀쩡한 타깃 2종	오탐 0 · 기권	예산 소진 후 exit 1, 거짓 성공 없음
미공개 유형 8종	전부 예산 내 발견	클라우드 추론 일반화 (파일·정답 접근 없음)
결정론	바이트 동일	오프라인 N=3 신규 실행 + 클라우드 캐시 리플레이
채점 조건	준수	Foundry v1.0.0 · 하네스 byte-identical · validate-submission PASS

05 왜 AutoPoC인가

■ 증명 기반

"의심"이 아니라 **실행되는 PoC**. 하네스가 깨져야만 성공 — 사람이 다시 검증할 필요가 없다.

■ 오프라인 결정론

키 없이도 공개셋 취약점 발견. 같은 입력 → **바이트 동일** 결과로 감사 추적 가능.

■ 오탐 0

멀쩡한 타깃엔 기권. 리포트의 모든 성공이 **실제 성립**임을 보장.

■ 미공개 일반화

본 적 없는 유형도 클라우드 추론으로 PoC 합성 — 정답 하드코딩 없이.

실행되는 PoC = 신뢰. **AutoPoC는 취약점을 주장하지 않고 증명한단다.**